RIVAYAT®

Security, performance and launch-readiness audit

Assessment date	11 October 2026
Target	www.rivayat.shop storefront and rivayat.onrender.com API
Method	Source review, automated functional tests, controlled non-destructive security checks, dependency audit and performance measurement
Outcome	No critical dependency or access-control issue found in the tested scope. Five material weaknesses were corrected; three architectural/deployment items remain for follow-up.

Important scope note

This was an authorized, controlled assessment of the owner’s application. It deliberately excluded denial-of-service activity, credential attacks, social engineering, destructive writes, access to real customer records and attempts to bypass hosting-provider controls. A passing result is not a guarantee that future vulnerabilities do not exist.

1. Executive result

Forgot password	FIXED	Hidden reset controls are disabled until code request succeeds; browser validation can no longer block the email step.
Password policy	VERIFIED	8–15 characters with at least one number and one symbol, enforced in client and server tests.
Performance	IMPROVED	Asset directory reduced from 40,485,633 bytes to 9,463,097 bytes (76.6% smaller). Product images total 3,434,378 bytes.
Security	HARDENED	CSP, clickjacking, MIME, referrer and permissions headers; CORS allowlist; request limits; input validation; protected-route checks.
Forms & email	CONNECTED	Contact form now calls the API, sends internal/confirmation mail when configured, and reports success/errors. Newsletter unsubscribe retained.
SEO/readiness	COMPLETED	Direct-route rewrites, sitemap/robots updates, FAQ, metadata, structured content and public-page coverage.
Automated verification	PASS	Catalogue, syntax, SVG navigation, auth policy, recovery flow, performance budgets, public assets and security regression tests all pass.

Measured performance

Asset directory	40.49 MB	9.46 MB	–76.6%
Product catalogue images	Large PNG set	3.43 MB WebP	32/32 optimized
Largest product image	>2 MB observed	246,816 bytes	Within 300 KB budget
Service-worker install	Heroes/categories/logos precached	Lean app shell only	Large visual assets deferred
Theme hero	Light and dark elements present	One active image element	Avoids duplicate hero download

2. Requested feature checklist

Dark-mode toggle	Complete	Theme-aware SVG navigation and active hero switching.
Cookie banner	Complete	Essential-only or consent-based analytics choice.
Search	Complete	Desktop/mobile search interface and API fallback.
Back to top	Complete	Floating control appears after scrolling.
Mobile menu	Complete	Drawer plus bottom navigation.
Loading animation	Complete	Startup shell and action states.
Hover effects	Complete	Cards, links and controls include interaction states.
Scroll progress	Complete	Top progress indicator bound to page scroll.
Copy action	Complete	Referral copy control retained.
Print CSS	Complete	Navigation, overlays and non-document controls hidden on print.
Sticky header	Complete	Persistent navigation header.
Skip to content	Complete	Keyboard-accessible skip link focuses main content.
Password visibility	Complete	Show/hide controls for login, signup and reset.
UTM tracking	Complete	Source/medium/campaign captured; event sent only with consent.
Success/error states	Complete	Auth, contact and other actions expose status messages.
Confirmation dialogs	Complete	Destructive account/order actions retain confirmation.
Last updated	Complete	Policy/help content dated 11 October 2026.
Expandable FAQ	Complete	Seven disclosure-based answers on /faq.
Floating contact	Complete	WhatsApp action available across pages.

3. Pre-launch checklist

Privacy and terms	Complete	Linked legal pages and legal centre.
Secrets off frontend	Verified	No server secret is intentionally shipped in client code; environment files were not printed.
HTTPS	Live	Production domains use HTTPS/HSTS; deployment header checks must be repeated after release.
Cookie consent	Complete	Analytics remains off until explicit consent.
Meta and Open Graph	Complete	Canonical, OG, Twitter and route-specific metadata.
Favicon / PWA	Complete	Favicon, manifest and app icons.
Sitemap / robots	Complete	FAQ added; private/account/API paths remain blocked from indexing.
Image alternatives	Verified	Published storefront image references include alt text.
Compressed images	Complete	Catalogue/category/brand raster assets converted to WebP.
Speed	Improved	Performance budgets and lean service-worker precache added.
Contrast / themes	Reviewed	Explicit light/dark variables and theme-aware icons; retain periodic assistive testing.
Mobile	Covered	Responsive navigation, cookie layout and floating controls.
Custom 404	Complete	SPA not-found state with recovery links.
Broken internal assets	Verified	Tests resolve referenced assets and exercise public routes.
Form validation	Complete	HTML constraints plus server-side validation.
Spam protection	Improved	Honeypots and endpoint-specific rate limits.
Analytics	Complete	First-party event storage with anonymous HMAC session hash and 180-day TTL.
Calls to action	Complete	Shop, help, contact, work-with-us and account actions remain visible.

4. Functional verification

The release command regenerated search and merchant outputs, parsed the server and all inline browser JavaScript, and ran the regression suite. The following flows were checked without using real customer records.

Catalogue	32 unique products; unique IDs/slugs/images; stock and pricing constraints	Pass
Search feeds	32 Algolia records regenerated	Pass
Merchant feed	160 product-size records regenerated	Pass
Authentication	Login/signup/recovery API contracts; invalid-token boundary	Pass
Forgot password	Initial hidden controls, transition to code/password step, password constraints	Pass
Public routing	Home, policy, ownership, style, hero and static assets	Pass
Theme/navigation	SVG-only navigation shell; light/dark icon behavior	Pass
Contact/newsletter	Real API contract, bot trap, unsubscribe endpoints	Pass
Orders/returns/reviews	Client/server route families and existing contract coverage	Pass by source/route audit
Deployment	Vercel rewrites and security headers configured	Pending production rollout
Email delivery	Professional branded templates and recipients are implemented	Requires valid Resend/domain configuration

Test command

`npm run check` — passed in full. `npm audit --omit=dev` — 0 known vulnerabilities across info, low, moderate, high and critical severities.

5. Controlled security assessment

The assessment attempted safe attack classes against the local application boundary: hostile Origin/CORS, invalid bearer tokens, encoded path traversal, malformed password-recovery input, oversized payloads, header inspection and dependency-vulnerability discovery. It did not attempt brute force, account takeover, destructive writes or access to private data.

F-01 · High	Large PNG catalogue and heavy service-worker precache caused excessive transfer and install work.	Fixed: WebP conversion, 76.6% asset reduction, performance budgets, lean precache.
F-02 · Medium	Hidden required reset-password fields blocked the first recovery submission with ‘not focusable’ browser errors.	Fixed: fields start disabled and become enabled/required only after a successful code request.
F-03 · Medium	Static frontend lacked a complete deployment-level security-header policy.	Fixed: Vercel CSP, frame denial, MIME protection, referrer and permissions policies.
F-04 · Medium	All API routes accepted request bodies up to 16 MB, increasing resource-exhaustion exposure.	Fixed: ordinary routes limited to 1 MB; only image-based Style recommendation retains 16 MB.
F-05 · Medium	Contact was cosmetic and some public forms lacked a bot trap.	Fixed: API-backed contact mail, honeypots and endpoint-specific limits.
F-06 · Medium · residual	Custom bearer tokens are stored in localStorage while the current CSP permits inline script for the single-file SPA.	Recommended: complete Clerk or another mature auth migration with secure cookie/session design and remove unsafe-inline through script extraction/nonces.
F-07 · Low/Medium · residual	Rate-limit counters are process-local and reset on restart or scale-out.	Recommended: use a shared Redis/Upstash limiter for production-wide enforcement.
F-08 · Operational · residual	At baseline, the Render health response did not expose the new build version, indicating the API deployment was behind source.	Required after commit: wait for/restart Render deployment, then confirm health version and recovery/email flow.

6. Security test record

Hostile Origin	Reject; no Access-Control-Allow-Origin	403; no allow-origin header; pass
Invalid admin bearer	No protected data	403; pass
Encoded traversal	Do not expose server.js or secrets	Non-200; no source markers; pass
Malformed recovery email	Reject before database lookup	400; pass
Oversized ordinary JSON	Limit request	413 with generic response; pass
Security headers	CSP, DENY framing, nosniff	Present in local API and configured for Vercel; pass
Dependency audit	No known production advisories	0 vulnerabilities; pass
Error leakage	No stack/file paths in tested failures	No leakage observed; pass

Deployment acceptance steps

1. Confirm Vercel serves the new CSP and direct /forgot-password and /faq routes. 2. Confirm Render /health reports build `2026-10-11-performance-security-v1`. 3. Request exactly one reset code for an owned test email and complete the browser flow. 4. Submit one owned contact test and verify internal recipients plus customer confirmation. 5. Check consent choices and one analytics page-view record. 6. Monitor error and rate-limit telemetry after launch.

Conclusion

The release is materially faster and safer than the audited baseline. The reported browser-breaking recovery bug is corrected, launch checklist gaps are filled, and the automated suite prevents the same regressions. Production acceptance still depends on successful Vercel/Render rollout and correctly configured email, database and third-party credentials.

Prepared for RIVAYAT / Shukla Group of Companies